Controls and compliance checklist

To complete the controls assessment checklist, refer to the information provided in the scope, goals, and risk assessment report. For more details about each control, including the type and purpose, refer to the control categories document.

Then, select “yes” or “no” to answer the question: *Does Botium Toys currently have this control in place?*

Controls assessment checklist

Yes	No	Control
☐	☑	Least Privilege
☐	☑	Disaster recovery plans
☐	☑	Password policies
☐	☐	Separation of duties
☑	☐	Firewall
☐	☑	Intrusion detection system (IDS)
☐	☑	Backups
☑	☐	Antivirus software
☑	☐	Manual monitoring, maintenance, and intervention for legacy systems
☐	☑	Encryption
☐	☑	Password management system
☑	☐	Locks (offices, storefront, warehouse)
☑	☐	Closed-circuit television (CCTV) surveillance

☑	☐	Fire detection/prevention (fire alarm, sprinkler system, etc.)

To complete the compliance checklist, refer to the information provided in the scope, goals, and risk assessment report. For more details about each compliance regulation, review the controls, frameworks, and compliance reading.

Then, select “yes” or “no” to answer the question: *Does Botium Toys currently adhere to this compliance best practice?*

Compliance checklist

Payment Card Industry Data Security Standard (PCI DSS)

Yes	No	Best practice
☐	☑	Only authorized users have access to customers’ credit card information.
☐	☑	Credit card information is stored, accepted, processed, and transmitted internally, in a secure environment.
☐	☑	Implement data encryption procedures to better secure credit card transaction touchpoints and data.
☐	☑	Adopt secure password management policies.

General Data Protection Regulation (GDPR)

Yes	No	Best practice
☐	☑	E.U. customers’ data is kept private/secured.
☑	☐	There is a plan in place to notify E.U. customers within 72 hours if their data is compromised/there is a breach.
☐	☑	Ensure data is properly classified and inventoried.

☐	☑	Enforce privacy policies, procedures, and processes to properly document and maintain data.

System and Organizations Controls (SOC type 1, SOC type 2)

Yes	No	Best practice
☐	☑	User access policies are established.
☐	☑	Sensitive data (PII/SPII) is confidential/private.
☐	☑	Data integrity ensures the data is consistent, complete, accurate, and has been validated.
☐	☑	Data is available to individuals authorized to access it.

Recommendations

Based on the controls and compliance assessment, the following recommendations are proposed to improve Botium Toys' security posture, protect sensitive information, and reduce potential business risks.

1. Implement Access Controls and Least Privilege

Botium Toys should implement role-based access control (RBAC) to ensure employees can access only the data and systems required for their job responsibilities. Separation of duties should also be established to reduce the risk of unauthorized activities and misuse of sensitive information.

2. Strengthen Data Protection and Encryption

The company should implement encryption to protect customers' credit card information and other sensitive data, both at rest and during transmission. Access to payment card

information should be restricted to authorized personnel to reduce the risk of data exposure and support applicable PCI DSS requirements.

3. Establish Regular Data Backups and Disaster Recovery Plans

Botium Toys should create regular, secure backups of critical business data and test the restoration process periodically. A disaster recovery plan should be documented and tested to ensure business operations can recover following data loss, cyberattacks, or system failures.

4. Improve Password Security

The company should strengthen its password policy by enforcing appropriate password requirements and implementing a centralized password management solution. Multi-factor authentication (MFA) should also be introduced, particularly for privileged accounts and access to sensitive systems.

5. Improve Threat Detection and Monitoring

An intrusion detection system (IDS), or an appropriate intrusion detection and prevention solution, should be implemented to help identify suspicious network activity. The IT department should regularly review security logs, investigate alerts, and ensure antivirus software and firewall rules remain effective.

6. Improve Asset Management and Data Classification

Botium Toys should maintain an up-to-date inventory of hardware, software, systems, and data assets. Assets should be classified according to their sensitivity and business importance so that appropriate security controls and protection measures can be applied.

7. Establish a Legacy System Maintenance Schedule

The IT department should create a documented schedule for monitoring, maintaining, and updating legacy systems. Unsupported systems should be identified, isolated

where appropriate, and replaced or upgraded when feasible to reduce exposure to security vulnerabilities.

8. Strengthen Compliance and Incident Response

Botium Toys should review its privacy policies, security procedures, and incident response plan to ensure they are documented, communicated, and regularly tested. The company should evaluate its obligations under applicable regulations and standards, including GDPR and PCI DSS, and maintain appropriate evidence of compliance.

Conclusion

Implementing these recommendations in order of risk priority will help Botium Toys protect sensitive customer information, improve access control, strengthen threat detection, and support business continuity. Regular security reviews and monitoring should be conducted to measure progress and ensure that implemented controls remain effective.